

Suite de Auditoría de Seguridad en Python

Guía de Desarrollo: Parte II - Enumeración y Ataques

Prof. César Rodríguez

Semanas 5 a 7

Resumen

El presente documento detalla los requerimientos teóricos y el flujo de trabajo colaborativo para los 4 grupos de desarrollo durante la **Fase II: Enumeración y Ataques** del proyecto. Esta etapa se apoya fuertemente en los conceptos del libro de texto *“Hackers 6: Secretos y soluciones de seguridad en redes”*.

1. Parte I: Fundamentos Teóricos por Grupo

Cada grupo debe investigar y dominar los siguientes conceptos teóricos antes de comenzar a codificar sus respectivos módulos.

Grupo 1: Enumeración y Banner Grabbing

- **Base literaria:** Capítulo 3 (Enumeración / Captura de anuncios básica).
- **Conceptos clave:** Entender cómo interactuar a bajo nivel con los servicios de red. El grupo debe estudiar cómo los clientes legítimos (y los atacantes empleando herramientas como `telnet` o `netcat`) obtienen información del vendedor y la versión del software a partir del “saludo” (banner) del servidor.
- **Tecnología:** Programación de sockets en Python (`socket`) y manipulación de cadenas empleando Expresiones Regulares (`re`) para limpiar los caracteres no imprimibles.

Grupo 2: Enumeración NetBIOS/SMB (Entornos Windows)

- **Base literaria:** Capítulo 4 (Hacking de Windows / Enumeración de sesión NetBIOS y SMB).
- **Conceptos clave:** Comprender la gravedad de las configuraciones predeterminadas en sistemas Windows heredados. El grupo debe dominar el concepto de *Sesión Nula* (Null Session / IPC\$) y cómo ésta permite extraer de forma anónima listas de usuarios, políticas de contraseñas y recursos compartidos.
- **Tecnología:** Puertos TCP 139 y 445. Integración de librerías externas en Python orientadas a SMB (ej. `pysmb`).

Grupo 3: Ataques de Autenticación en Red (Fuerza Bruta)

- **Base literaria:** Capítulo 5 (Hacking de UNIX / Ataques de fuerza bruta).
- **Conceptos clave:** Analizar la debilidad de las contraseñas humanas. Entender la diferencia entre un ataque de diccionario y uno de fuerza bruta pura. El grupo se enfocará en automatizar el inicio de sesión contra protocolos de transferencia como FTP.
- **Tecnología:** Manejo de la librería `ftplib` en Python. Es imperativo que este grupo estudie el manejo de concurrencia (`threading` y `queue`) para evitar que el ataque secuencial tome un tiempo inviable.

Grupo 4: Fuerza Bruta Web e Integración General

- **Base literaria:** Capítulo 11 (Hacking de Web / Formularios y Autenticación).
- **Conceptos clave:** Diferenciar entre peticiones HTTP GET y POST. Analizar cómo interactuar de manera automatizada con formularios HTML que requieren autenticación.
- **Tecnología:** Manejo de la librería externa `requests` en Python, manejo de sesiones, y estructuración de datos genéricos (Diccionarios y Listas) para el reporte de salida.

2. Parte II: Dinámica y Flujo de Trabajo

Debido a la naturaleza modular del proyecto, existe la inquietud de que un grupo no pueda avanzar sin que el anterior haya terminado. **Para evitar este cuello de botella, se ha diseñado una arquitectura basada en Programación Orientada a Objetos (POO).**

El flujo de trabajo se dividirá en dos etapas para asegurar la máxima eficiencia:

1. Etapa de Desarrollo en Paralelo (Semanas 5 y 6)

Los Grupos 1, 2, 3 y la primera mitad del Grupo 4 no necesitan esperar a nadie para comenzar a programar.

- Cada grupo ha recibido una plantilla de código (una Clase en Python) completamente aislada.
- **Estructura de directorios:** Todos los archivos de código fuente (`.py`) deben guardarse y ejecutarse obligatoriamente desde la carpeta `modulos/`. Mantener este estándar, establecido desde la Fase I, es fundamental para asegurar que las clases se importen correctamente en la etapa final de integración.
- Cada script cuenta con un bloque `if __name__ == '__main__':` al final. Esto significa que el Grupo 1 puede probar su `BannerGrabber` contra su propia computadora (`127.0.0.1`), mientras el Grupo 2 prueba su `SMBEnumerator` contra una máquina virtual Windows de prueba.
- Los grupos pueden avanzar, cometer errores y depurar su código de manera 100 % independiente. El único requisito es que al finalizar, sus módulos devuelvan un diccionario de Python con los datos estandarizados.

2. Etapa de Sincronización e Integración (Semana 7)

Aquí es donde entra la única dependencia obligatoria del proyecto.

- El **Grupo 4** actuará como el equipo de Arquitectura. Una vez que hayan terminado su propio módulo de ataque Web, deberán solicitar los archivos `.py` finalizados de los Grupos 1, 2 y 3.
- El Grupo 4 creará un script integrador (`main.py`). Debido a que los otros grupos programaron sus herramientas como Clases, el Grupo 4 solo tendrá que importar estas clases e instanciarlas.
- **Ejemplo de dependencia:** El módulo principal ejecutará primero las herramientas de la *Fase I* para descubrir qué puertos están abiertos. Si el puerto 21 está abierto, el `main.py` llamará automáticamente a la clase del Grupo 1 para obtener el Banner, y luego llamará a la clase del Grupo 3 para intentar un ataque de fuerza bruta.

Nota para los estudiantes: La comunicación inter-grupal es vital durante la Etapa 1. Si el Grupo 2 decide cambiar el formato en que devuelve la lista de usuarios SMB, debe informarlo inmediatamente al Grupo 4 para que éste adapte el código del programa principal.

3. Parte III: Glosario de Términos

Para asegurar una comprensión uniforme de los conceptos técnicos aplicados en esta fase, se definen los siguientes términos clave:

Ataque de Diccionario

Variante del ataque de fuerza bruta que, en lugar de probar todas las combinaciones posibles, utiliza una lista predefinida de palabras o contraseñas comunes (diccionario) para agilizar el descubrimiento de credenciales.

Banner Grabbing

Técnica de recolección de información (enumeración) que consiste en conectarse a un puerto de red y capturar el mensaje de bienvenida (banner) para identificar el nombre y la versión del software que se está ejecutando.

Fuerza Bruta (Brute Force)

Método de ataque automatizado que consiste en probar repetida y sistemáticamente credenciales (nombres de usuario y contraseñas) contra un mecanismo de autenticación hasta dar con la combinación correcta.

Hilo (Thread) / Concurrencia

Secuencia de instrucciones que puede ser administrada de forma independiente por el sistema operativo. En los módulos de ataque (Grupos 3 y 4), el uso de hilos en Python permite realizar múltiples intentos de conexión de red de forma simultánea, ahorrando horas de tiempo.

NetBIOS / SMB

(Server Message Block) Protocolos de red utilizados predominantemente en entornos Microsoft Windows para compartir archivos, impresoras y habilitar la comunicación entre procesos a través de la red.

Programación Orientada a Objetos (POO)

Paradigma de programación basado en el concepto de 'clases' y 'objetos' que encapsulan datos y funciones. Su uso en esta fase garantiza que el código de cada grupo sea independiente, modular e integrable en el `main.py` de la Fase III.

Sesión Nula (Null Session)

Conexión anónima a un recurso compartido oculto (normalmente IPC\$) en sistemas Windows heredados. Permite a un atacante, sin nombre de usuario ni contraseña, enumerar recursos, usuarios y políticas de red.

Socket

Punto final de una conexión de red bidireccional. Es la interfaz de software de más bajo nivel que utilizarán en Python (especialmente el Grupo 1) para enviar y recibir datos a través de TCP/IP.